SAVEETHA
INSTITUTE OF MEDICAL AND TECHNICAL SCIENCES
(Declared as Deemed to be University under Section 3 of UGC Act 1956)

**Name:** A. Midhuna

**Register No:**192521302

**Course:** CSA5102 Cryptography and Network Security

## ASSIGNMENT 1

## QUESTIONS

**CO1**: Apply classical encryption techniques using symmetric and asymmetric ciphers to encrypt and decrypt data for the ensuring data security.

**Assignment Title:** Evaluate, Design and Defend a Secure Patient Record Exchange Strategy for a Multi-Hospital Healthcare Network (Total Marks: 50)

**Scenario — Confidential Patient Record Exchange**

A regional healthcare network links one central hospital with 25 satellite clinics. Clinics send patient records, diagnostic reports, prescriptions and billing data to the central hospital over a public network and receive specialist opinions in return. Personnel hold different clearance levels: Medical Director (Top Secret), Specialist Doctors (Secret), Nurses and Lab Staff (Confidential), Billing and Front-Desk Staff (Restricted), Patients (Public).

The system must:

● Keep diagnoses, especially for sensitive conditions, confidential.

● Detect tampering with prescriptions, dosage and lab values.

● Prevent staff from reading or writing records beyond their clearance.

● Work in rural clinics where staff have limited technical training and hardware is basic.

You must evaluate, design and defend a protection strategy built only from classical (pre-modern) techniques and access-control reasoning covered in CO1. You are expected to judge how strong each technique actually is, not just describe it.

**Design Challenge** : An insider at a satellite clinic has been copying ciphertexts for months. Hundreds of messages under the same key are now exposed, and many begin with predictable text (e.g., "PATIENT ID", "DIAGNOSIS:", "PRESCRIPTION:"). The network also wants to embed a short report inside medical scan images sent between

hospitals. Re-evaluate your design.

● Encrypt clinical notes (200 to 10,000 characters) using Caesar, monoalphabetic, Vigenère and columnar transposition, and derive each key space. Break at least three schemes by frequency analysis, Kasiski or index of coincidence, and rank the schemes by resistance.

● Extend the alphabet to digits and symbols (mod 36) and encrypt IDs and dosages such as PT-20481, AMOX 500MG using a Hill cipher on 3-character blocks. Prove the key's invertibility, compute one inverse, and recover the key by a known-plaintext attack.

● Apply columnar transposition to a lab table of 20+ rows and test whether a changed cell or a swapped row is detected. Design a classical checksum and show where an attacker defeats it.

● Encrypt a 256×256 or larger medical image with two classical methods (intensity shift mod 256 and pixel permutation) and verify decryption. Compare histograms and entropy, and explain which method leaks the image's structure.

● Hide a short report in an image by LSB embedding and in a text circular by a text method, then extract it. Measure PSNR, capacity and chi-square detectability, and test survival under JPEG compression.

● Decide 12+ access requests using Bell-LaPadula with compartments, including declassification and break-glass cases. Rank six attacks by likelihood × impact and recommend a final design, stating which security goals classical techniques cannot meet.

**TASK 1 – Evaluate Threats, Attacks and Risks 4 Marks**

Identify at least six security attacks relevant to the healthcare scenario.

● Classify each as passive or active (eavesdropping, traffic analysis, modification of prescriptions, masquerade as a doctor, replay of old orders, denial of service on the records system).

● Distinguish clearly between threat, vulnerability, attack and risk, with examples from this scenario.

● Rank the attacks by risk using a justified likelihood × impact rating. Consider patient-safety impact, not just privacy.

● Defend your ranking: which attack would you address first, and why?

**Evidence Expected**: A risk table with reasoned ratings and a justification of the priority order.

**Answer:**

**Classification of security attacks**

Eavesdropping – Passive: Secretly listening to confidential patient information.

Traffic Analysis – Passive: Monitoring communication patterns to identify patient or doctor activities.

Modification of Prescriptions – Active: Changing medicine or dosage without permission.

Masquerading as a Doctor – Active: Pretending to be an authorized doctor to access records.

Replay of Old Orders – Active: Resending old medical orders to create unauthorized actions.

Denial of Service – Active: Disrupting the records system and preventing doctors from accessing patient data.

**Difference between Threat, Vulnerability, Attack and Risk**

Threat: A potential danger that can harm the healthcare system. Example: A hacker attempting to steal patient records.

Vulnerability: A weakness in the system that an attacker can exploit. Example: Weak passwords, outdated software or lack of encryption.

Attack: An intentional action performed to exploit a vulnerability. Example: An attacker modifies a patient's prescription.

Risk: The possibility of damage or loss when a threat exploits a vulnerability. Example: A patient receives the wrong medicine, resulting in serious health complications.

**Risk Ranking (Likelihood × Impact)**

Modification of prescriptions – High risk

Masquerading as a doctor – High risk

Denial of Service – High risk

Replay of old orders – High risk

Eavesdropping – Medium risk

Traffic Analysis – Medium risk

**Justification of Ranking**

Modification of prescriptions should be addressed first.

Incorrect medicines or dosages can put patients' lives at risk.

It can cause serious health complications.

Regular monitoring helps prevent unauthorized changes.

**TASK 2 – Map and Judge Security Goals 3 Marks**

For each system function (record upload, prescription transmission, specialist consultation), decide which goals matter most: confidentiality integrity availability authentication non-repudiation

● Judge which goals classical ciphers can and cannot deliver.

● Justify why a correctly decrypted message does not prove it came from the right doctor, or that its dosage was not altered.

**Evidence Expected**: A goal-to-function analysis with an evaluation of the gaps classical techniques leave.

**Answer**:

**Security Goals for Each System Function**

- Record Upload: Confidentiality, integrity and authentication are important to protect patient records.
- Prescription Transmission: Integrity, authentication, confidentiality and non-repudiation are important to prevent prescription changes.
- Specialist Consultation: Confidentiality, availability, authentication and integrity are important for secure communication.

**Classical Ciphers – Advantages and Limitations**

- Classical ciphers provide basic confidentiality by hiding the original message.
- They cannot guarantee integrity, authentication, availability or non-repudiation.
- They are weak against modern attacks.

**Justification**

- Correct decryption only shows that the message was successfully decoded.
- It does not prove that the message came from the correct doctor.
- It cannot confirm whether the medicine dosage was altered.
- Digital signatures and message authentication are needed for verification.

**TASK 3 – Apply and Critique the Bell-LaPadula Model 5 Marks**

● Define the security levels and subject/object assignments for the network.

● Apply the simple security property (no read up) and the *-property (no write down) to at least five access requests, including two that must be denied. Show the reasoning for each.

● Evaluate the model critically in a medical setting: what happens in an emergency when a nurse needs a Secret-level allergy record? How does the model handle a doctor who must write a note to a lower-level billing file? Discuss tranquility and trusted subjects.

● Judge the model's limitations (no integrity guarantees, covert channels, rigidity in emergencies) and argue whether Bell LaPadula alone suits healthcare.

**Evidence Expected:** Worked access decisions, a justified critique, and a clear verdict on the model's suitability.

**Answer**:

**Define Security Levels and Subject/Object Assignments**

Bell-LaPadula is a security model used to protect confidential information by controlling who can read and write data.

- Top Secret: Hospital administrators who can access highly sensitive hospital information.
- Secret: Doctors and specialists who can access patient medical records.
- Confidential: Nurses who can access patient care information.
- Unclassified: Billing staff who can access basic billing and payment details.

**Access Requests and Decisions**

- Doctor reading Secret patient records – Allowed (same level).
- Nurse reading Secret allergy records – Denied (No Read Up).
- Doctor reading Confidential records – Allowed (No Read Up).
- Doctor writing to Confidential billing files – Denied (No Write Down).
- Nurse writing to Confidential patient records – Allowed (same level).

**Critical Evaluation in a Medical Setting**

- During emergencies, a nurse may need to access a Secret-level allergy record to provide immediate treatment.
- Bell-LaPadula denies this access because the nurse has only Confidential clearance.
- This restriction may delay treatment and put the patient's life at risk.
- A doctor may need to write medical information into a lower-level billing file, but No Write Down prevents this action.
- Tranquility: It prevents security levels from changing improperly during system operation.
- Trusted Subjects: Authorized users can be given special privileges to perform necessary operations under controlled conditions.
- Emergency access can be provided through a controlled break-glass mechanism with authorization and audit logging.

**Limitations and Conclusion**

- Bell-LaPadula mainly focuses on confidentiality and does not guarantee data integrity.
- It cannot prevent unauthorized modification of medical records by itself.
- Covert channels may allow information to leak indirectly.
- Strict security rules can create delays during medical emergencies.
- It does not fully address the practical needs of doctors and nurses.

**TASK 4 – Design the Cryptographic Strategies 4 Marks**

Select at least three meaningfully different classical schemes from: Caesar, monoalphabetic substitution, Vigenère (polyalphabetic), Hill cipher, a transposition cipher. For each, provide:

● The encryption and decryption algorithm (pseudocode or formula) and the key definition.

● A worked example on a 20+ character message from the scenario.

● A justification for including it in your comparison.

**Evidence Expected:** Three distinct schemes with algorithms, worked examples and justified selection.

**Answer:**

**Design the Cryptographic Strategy (4 Marks)**

Three different classical encryption techniques are selected to compare how they protect confidential healthcare messages.

1. Caesar Cipher

Key: Shift value = 3.

Encryption formula: $C=(P+3)\mod 26$

Decryption formula: $P=(C-3)\mod 26$

Algorithm:

- Take the plaintext message.
- Shift each letter three positions forward.
- For decryption, shift each letter three positions backward.

Worked Example:

Plaintext: PATIENT NEEDS URGENT MEDICINE

Ciphertext: SDWLHQW QHHGV XUJHQW PHGLFLQH

Justification:

- Easy to understand and implement.
- Useful for basic comparison.
- Provides very weak security and can be easily broken.

**Monoalphabetic Substitution Cipher**

Key: A fixed substitution alphabet.

Plain alphabet: ABCDEFGHIJKLMNOPQRSTUVWXYZ

Cipher alphabet: QWERTYUIOPASDFGHJKLZXCVBNM

Algorithm:

- Replace each plaintext letter with its corresponding key letter.
- For decryption, use the reverse substitution mapping.

Worked Example:

Plaintext: PATIENT NEEDS URGENT MEDICINE

Ciphertext: GQZOTDZ FTTEX ZKRTFZ FTETOIF

Justification:

- Uses a different replacement for every alphabet letter.

- Provides more possible keys than Caesar cipher.
- It is still vulnerable to frequency analysis.

**Vigenère (Polyalphabetic) Cipher**

Key: HEALTH (repeated to match the message length).

Encryption formula: \(C_i=(P_i+K_i)\mod 26\)

Decryption formula: \(P_i=(C_i-K_i)\mod 26\)

Algorithm:

- Take the plaintext and secret key.
- Repeat the key until it matches the message length.
- Add the plaintext and key letter values to encrypt.
- Subtract the key values to decrypt.

Worked Example:

Plaintext: PATIENT NEEDS URGENT MEDICINE

Key: HEALTH HEALTH HEALTH HEALTH

Ciphertext: WETTXUA REPWZ BVGPGA TIDTVPUI

Justification:

- Uses multiple substitution alphabets.
- More secure than Caesar and monoalphabetic substitution.
- Suitable for comparing different encryption methods.

**Conclusion:**

The three classical ciphers provide different levels of confidentiality. Vigenère is stronger than Caesar and monoalphabetic substitution, but all three are weak against modern attacks. They cannot provide authentication, integrity or non-repudiation required in healthcare systems.

**TASK 5 – Mathematical Analysis of the Schemes 5 Marks**

● Derive the key-space size of each scheme (e.g., 25, 26!, 26^m, number of invertible n×n matrices mod 26, n! permutations). ● For Hill: show the conditions under which $K^{-1}$ mod 26 exists (gcd(det K, 26) = 1), and compute one inverse by hand.

● Express each encryption as a modular function (e.g., C = (aP + b) mod 26 for an affine variant, C = KP mod 26 for Hill).

● Judge whether a large key space guarantees strength. Support your answer with the monoalphabetic example.

**Evidence Expected**: Correct derivations with a reasoned judgment on key space versus real security.

Answer:

**Mathematical Analysis of the Schemes (5 Marks)**

1. Key-Space Size of Each Scheme

Key space means the total number of possible keys available for encryption.

- Caesar Cipher: There are 25 possible keys (excluding zero shift).
  Key space = 25.
- Monoalphabetic Substitution: There are 26! possible keys because all 26 letters can be rearranged.
  Key space = 26! ≈ $4.03 \times 10^{26}$.
- Vigenère Cipher: For a key of length $m$, there are 26 possible letters at each position.
  Key space = $26^m$.
- Hill Cipher: The key space is the number of invertible $n \times n$ matrices modulo 26. A key is valid only when its determinant is relatively prime to 26.
- Transposition Cipher: For a message of length $n$, the number of possible rearrangements is $n!$.

2. Hill Cipher – Inverse Condition and Calculation

For a Hill cipher, the inverse key matrix exists only when:

$$\gcd(\det K,26)=1$$

Take the key matrix:

$$K=\begin{bmatrix}3&3\\2&5\end{bmatrix}$$

Step 1: Find determinant.

$$\det K=(3\times5)-(3\times2)=9$$

Step 2: Check the condition.

$$\gcd(9,26)=1$$

Therefore, the inverse exists.

3. Modular Functions of Encryption Schemes

- Caesar Cipher:

$$ C=(P+3)\mod 26 $$

- Monoalphabetic Substitution:

$$ C=f(P) $$

Each plaintext letter is replaced by a fixed corresponding ciphertext letter.

- Vigenère Cipher:

$$ C_i=(P_i+K_i)\mod 26 $$

- Hill Cipher:

$$ C=KP\mod 26 $$

- Transposition Cipher:

$$ C_i=P_{\pi(i)} $$

Here, $\pi$ represents the key-controlled rearrangement of letter positions.

4. Hill Cipher – Finding the Inverse Matrix

Given:

$$ K=\begin{bmatrix}3&3\\2&5\end{bmatrix} $$

The inverse of 9 modulo 26 is 3 because:

$$ 9\times3=27\equiv1\pmod{26} $$

Adjoint matrix:

$$ Adj(K)=\begin{bmatrix}5&-3\\-2&3\end{bmatrix} $$

Therefore,

$$ K^{-1}=3 \begin{bmatrix}5&-3\\-2&3\end{bmatrix}\mod26 $$

Final inverse:

$$ \boxed{K^{-1}= \begin{bmatrix}15&17\\20&9\end{bmatrix}} $$

5. Does a Large Key Space Guarantee Security?

- A large key space does not always guarantee strong security.

- Monoalphabetic substitution has 26! possible keys, which is a very large number.
- However, it can be broken using frequency analysis.
- Attackers can identify commonly repeated letters and guess the original message.
- Therefore, security depends on the encryption method and its resistance to attacks, not only on key-space size.

Conclusion:

Classical encryption schemes provide basic confidentiality but cannot provide complete security for healthcare systems. Modern encryption methods, authentication and digital signatures are needed to protect patient information.

**TASK 6 – Evaluate Cryptanalytic Resistance 4 Marks**

Attack each chosen scheme using a technique suited to it:

● Brute force, frequency analysis, Kasiski examination / index of coincidence, known-plaintext attack on Hill, digram analysis.

● Explain why each attack succeeds or fails, in terms of letter frequency preservation, key repetition and linearity.

● Rank the schemes by resistance and justify the ranking with evidence.

**Evidence Expected:** Worked attacks with reasoning, and a ranking of schemes supported by the results.

**Answer:**

**Evaluate Cryptanalytic Resistance (4 Marks)**

1. Attacks on Different Classical Schemes

1. Caesar Cipher – Brute Force Attack

- Caesar cipher has only 25 possible keys.
- An attacker can try all 25 shifts to find the original message.
- It is easy to break because the key space is very small.
- Example: KHOOR → Shift backward by 3 → HELLO.

2. Monoalphabetic Substitution – Frequency Analysis

- Each plaintext letter is replaced by a fixed letter.

- The frequency of letters remains the same.
- Attackers use common letters like E, T and A to identify the message.
- Therefore, it can be broken using frequency analysis.

3. Vigenère Cipher – Kasiski Examination

- The same key is repeated throughout the message.
- Repeated ciphertext patterns can reveal the key length.
- After finding the key length, frequency analysis can help recover the key.
- Longer and non-repeating keys make the attack more difficult.

4. Hill Cipher – Known-Plaintext Attack

- Hill cipher uses matrix multiplication for encryption.
- If attackers know enough plaintext and corresponding ciphertext blocks, they can calculate the key matrix.
- Its linear structure makes it vulnerable to known-plaintext attacks.

2. Why These Attacks Succeed or Fail

- Caesar preserves letter patterns and has a small key space.
- Monoalphabetic substitution preserves letter frequency, making frequency analysis effective.
- Vigenère hides single-letter frequency better, but repeated keys create patterns.
- Hill cipher uses linear equations, allowing attackers to recover the key with sufficient known plaintext.

3. Ranking of Schemes by Cryptanalytic Resistance

1. Vigenère Cipher: More resistant because it uses multiple substitution alphabets.
2. Hill Cipher: Provides better letter mixing but is vulnerable to known-plaintext attacks.
3. Monoalphabetic Substitution: Vulnerable to frequency analysis.
4. Caesar Cipher: Least resistant because it has only 25 possible keys.

Conclusion:

Vigenère provides better resistance among these classical schemes, while Caesar is the easiest to break. However, none of these methods is secure enough for modern healthcare communication. Modern encryption techniques are required to protect patient records and prescriptions.

**TASK 7 – Assess Transposition and Product Ciphers 3 Marks**

● Implement a columnar (or rail-fence) transposition and explain how it diffuses plaintext structure.

● Evaluate whether *substitution followed by transposition* is stronger than either alone. Justify with letter-frequency evidence and an attack attempt.

● Judge whether the added complexity is practical for rural clinic staff doing

manual or low-resource encryption.

**Evidence Expected:** A reasoned evaluation of the combined scheme against its components.

**Answer:**

**Assess Transposition and Product Ciphers (3 Marks)**

1. Columnar Transposition Cipher

- Columnar transposition rearranges the positions of plaintext letters using a secret key.
- Example:

Plaintext: PATIENTNEEDSURGENTMEDICINE

Key: 3142

- Write the message row by row and read the columns in the order specified by the key.
- This method changes the letter positions but does not change the letters.
- It provides diffusion by hiding the original arrangement of the message.

2. Substitution Followed by Transposition

- Substitution replaces plaintext letters with different letters.
- Transposition rearranges the substituted letters.
- Combining both methods is stronger than using either method alone.
- Letter-frequency counts remain unchanged after transposition, but the original letter patterns become harder to identify.
- However, frequency analysis and other cryptanalytic attacks can still break classical product ciphers.

3. Practicality in Rural Clinics

- Both techniques require manual key management and careful processing.
- Combining them increases complexity and the chance of human errors.
- Rural clinic staff may find manual encryption and decryption difficult.
- Therefore, this method is useful for academic comparison but not practical for real healthcare communication.

Conclusion:

Substitution followed by transposition provides better protection than either technique alone. However, it is not strong enough for modern medical records. Secure digital encryption is recommended for healthcare systems.

**TASK 8 – Evaluate Steganography 3 Marks**

Design a steganographic method (e.g., LSB embedding in a scan image, or text-based hiding) for carrying a short report inside a medical image.

● Compare it with encryption on capacity,

imperceptibility, robustness and detectability.

● Evaluate the risk specific to medical imaging: could embedding alter pixel data enough to affect a diagnosis? Judge the trade-off.

● Judge when steganography is appropriate, and argue why hiding is not a substitute for encrypting. Evaluate an encrypt then-embed approach.

**Evidence Expected**: A criteria-based comparison with a justified conclusion.

**Answer:**

**Evaluate Steganography (3 Marks)**

1. Design of Steganographic Method

- Use the Least Significant Bit (LSB) method to hide a short medical report inside a medical image.
- Select a medical image and convert the report into binary data.
- Embed the binary data into the least significant bits of image pixels.
- The receiver extracts the hidden bits to recover the medical report.
- The image looks almost unchanged after embedding.

2. Comparison Between Steganography and Encryption

- Capacity: Steganography can hide data inside an image, while encryption protects data without hiding its existence.
- Imperceptibility: Steganography makes hidden information difficult to notice.
- Robustness: Steganography may lose hidden data when the image is compressed or edited. Encryption protects data even if it is copied, provided the key remains secure.
- Detectability: Steganography may be detected through statistical analysis, while encrypted data is visibly unreadable.

3. Risks in Medical Imaging

- Changing pixel values may affect the quality of medical images.
- Hidden data may interfere with diagnosis if important image details are altered.
- Even small changes should be carefully controlled.
- Therefore, original medical images must be preserved without modification.

4. Conclusion and Recommendation

- Steganography is useful for hiding confidential information during communication.
- However, hiding information is not a substitute for encryption.
- Encryption protects the actual content, while steganography hides its existence.
- An Encrypt-then-Embed approach first encrypts the medical report and then hides the encrypted data inside an image.
- This provides an additional layer of security, but the original medical image should always be preserved for accurate diagnosis.

**TASK 9 – Implement and Test**

**4 Marks**

Implement all chosen schemes, the cryptanalysis tools and (where feasible) the steganography method, in a language of your choice.

● Provide correctness tests: decrypt(encrypt(m)) = m, including edge cases (digits in patient IDs, punctuation, non-multiple block length for Hill).

● Use identical plaintexts of 100, 1,000, 10,000 and 100,000 characters across schemes.

● State the testing procedure clearly so it can be reproduced.

**Evidence Expected**: Working code with a documented, reproducible test procedure.

**Answer:**

**Implement and Test (4 Marks)**

1. Implementation

- Implemented Caesar, Monoalphabetic Substitution, Vigenère, Hill and Columnar Transposition ciphers using Python.
- Implemented cryptanalysis techniques such as brute force, frequency analysis and Kasiski examination.
- Implemented LSB steganography to hide a short medical report inside an image.

2. Correctness Testing

- Checked whether decrypt(encrypt(message)) returns the original message.
- Tested messages containing patient ID numbers, punctuation and special characters.
- Tested Hill cipher with message lengths that are not multiples of the block size by adding padding.
- Verified that the decrypted message matches the original message after removing padding.

3. Performance Testing

Used identical plaintexts across all schemes with different message lengths:

- 100 characters.
- 1,000 characters.
- 10,000 characters.
- 100,000 characters.

Measured encryption time, decryption time and execution performance for each scheme.

4. Testing Procedure

1. Write the original medical message as input.
2. Select the encryption algorithm and key.
3. Encrypt the message and generate ciphertext.

4. Decrypt the ciphertext using the same key.
5. Compare the decrypted message with the original message.
6. Repeat the process for all message sizes.
7. Record the results and verify correctness.

Conclusion:

All selected schemes were tested using different message lengths and input conditions. Correctness was verified by comparing the decrypted message with the original message. The testing procedure helps evaluate the accuracy and performance of each encryption technique.

**TASK 10 – Record and Interpret Experimental Evidence**

**3 Marks**

Present data in tables and graphs for:

● Letter-frequency histograms of plaintext versus each ciphertext. ● Index of coincidence per scheme.

● Encryption/decryption time against message size.

● Attack success rate against

ciphertext length. Evaluate what the

data shows. Do not just present it.

**Evidence Expected:** Clear, comparable results with interpretation tied to Tasks 5 and 6.

Answer:

**Record and Interpret Experimental Evidence (3 Marks)**

1. Letter-Frequency Histograms

- Compare the letter frequencies of the original plaintext with each encrypted ciphertext.
- Caesar and monoalphabetic ciphers preserve the original frequency pattern.
- Vigenère reduces visible frequency patterns by using multiple substitutions.
- Hill cipher mixes letters using matrix operations.
- This shows that different encryption methods produce different frequency distributions.

2. Index of Coincidence (IC)

- Calculate the Index of Coincidence for each ciphertext.
- Plaintext and monoalphabetic substitution generally have similar IC values.
- Vigenère usually has a lower IC when the key is repeated over a longer message.
- This helps identify patterns and estimate the strength of classical ciphers.

3. Encryption and Decryption Time

Test all schemes using the following message sizes:

- 100 characters
- 1,000 characters
- 10,000 characters
- 100,000 characters

Record encryption and decryption times for each message size. Generally, execution time increases as message length increases.

4. Attack Success Rate

- Caesar cipher is easily broken using brute force.
- Monoalphabetic substitution can be attacked using frequency analysis.
- Vigenère can be attacked using Kasiski examination.
- Hill cipher can be attacked using known-plaintext attacks.
- Longer ciphertexts may provide attackers with more information to identify patterns.

5. Interpretation and Conclusion

- Caesar and monoalphabetic ciphers are less resistant to cryptanalysis because they preserve letter frequencies.
- Vigenère provides better resistance because it uses repeated keys and multiple substitutions.
- Hill cipher provides better letter mixing but remains vulnerable to mathematical attacks.
- Larger message sizes help reveal statistical patterns and improve cryptanalysis.
- Therefore, experimental results help compare encryption speed, frequency patterns and attack resistance. Modern encryption is recommended for protecting healthcare information.

**TASK 11 – Recommend and Defend the Final Design 4**

**Marks**

Recommend one scheme, or a layered combination, together with the Bell-LaPadula policy.

● Justify against the alternatives using your mathematical and experimental evidence.

● State the residual risks and limitations honestly. Judge whether classical ciphers are acceptable for protecting patient data at all, and argue what a real deployment would need.

● Address key distribution across 25 clinics and usability for non technical staff.

**Evidence Expected:** A defended recommendation grounded in your own analysis, with candid limitations.

**DAY-4 DESIGN CHALLENGE**

**Answer:**

**Recommend and Defend the Final Design (4 Marks)**

Final Recommendation: AES Encryption + Bell-LaPadula Security Model

I recommend using AES (Advanced Encryption Standard) combined with the Bell-LaPadula security model to protect patient information in the healthcare system.

1. Justification of the Recommended Design

AES is more secure than classical encryption methods such as Caesar, Playfair and Vigenère ciphers. Classical ciphers can be broken using frequency analysis and other cryptanalysis techniques. AES provides strong encryption and better protection for sensitive patient records.

A layered security approach is recommended:

- AES: Encrypts patient records and prescriptions.
- Bell-LaPadula Model: Controls access based on security levels.
- Authentication: Ensures only authorized doctors and staff can access the system.
- Digital Signatures: Verify the authenticity of prescriptions and prevent unauthorized modifications.

2. Comparison with Alternatives

AES is preferred over classical ciphers because it provides stronger security and resists frequency-analysis attacks. Experimental results and mathematical analysis can demonstrate the weaknesses of classical ciphers through their frequency distributions, index of coincidence and attack success rates.

3. Residual Risks and Limitations

Even AES has some limitations:

- Stolen encryption keys can expose patient information.
- Weak passwords may allow unauthorized access.
- Insider attacks can still occur.
- System failures and denial-of-service attacks may interrupt healthcare services.
- Human errors may cause accidental data leakage.

Classical ciphers are not acceptable for protecting real patient data because they can be easily broken and do not provide sufficient modern security.

4. Key Distribution Across 25 Clinics

A centralized Key Management System (KMS) should be used to manage encryption keys across all 25 clinics.

- Each clinic should have its own unique encryption keys.
- Keys should be distributed securely.
- Only authorized administrators should manage keys.
- Regular key rotation and backup should be performed.
- Compromised keys should be revoked immediately.

5. Usability for Non-Technical Staff

The system should provide a simple user interface for doctors, nurses and other staff. Encryption and decryption should happen automatically in the background. Staff should only need to log in using secure authentication. This reduces technical difficulties and human errors.

Conclusion

AES combined with the Bell-LaPadula model is the recommended design because it provides strong data confidentiality and controlled access. However, real-world healthcare deployment also requires secure key management, authentication, digital signatures, regular security audits and staff training. Therefore, classical ciphers may be useful for academic experiments but should never be used to protect actual patient data.

**TASK 12 – Re-evaluate and Adapt the Design  8 Marks**

**Changed Requirement**: A clinic insider has copied hundreds of ciphertexts under the same key, many with predictable headers. The network also wants reports hidden inside medical scan images.

You may RETAIN → MODIFY → or REDESIGN your original solution.

**A. Impact Analysis (2 Marks)**

● What has changed in the threat model (insider versus external attacker)?

● Which earlier assumptions fail (key secrecy at all 25 sites, key reuse, message predictability)?

● Why does a high volume of known-format messages change the risk ranking?

**B. Evaluation of the Original Design (2 Marks)** ● Test your recommended scheme against the new attacker capabilities (known plaintext, repeated-key attacks).

● Support the evaluation with a demonstration or calculation.

● Where does the Bell-LaPadula policy still hold, and where is it irrelevant against an insider who holds the key?

**C. Adaptation or Redesign (2 Marks)**

● Decide to retain, modify or redesign. For example, consider per-clinic or per-session keys, key rotation, randomised padding, removing fixed headers, layering transposition, or encrypt-then-embed.

● Describe what changes and how it affects the key space and attack effort.

**D. Evidence-Based Defence (2 Marks)**

Defend the final decision with your key-space mathematics, your experimental results, the insider threat, the usability and key management cost for clinics, and a stated judgement on what classical techniques can never guarantee for patient data.

**Answer:**

**Re-evaluate and Adapt the Design (8 Marks)**

Decision: MODIFY the Original Design

The original design used AES encryption with the Bell-LaPadula security model. Due to the new insider threat and the requirement to hide reports inside medical scan images, the system must be modified to provide additional security.

**A. Impact Analysis (2 Marks)**

The threat model has changed because an insider from one of the clinics has copied hundreds of encrypted messages. Unlike an external attacker, the insider may already have authorized access to the system.

Earlier assumptions that no one could access encryption keys at all 25 clinics are no longer reliable. Reusing the same key for many messages also increases the risk of attacks.

Predictable headers, repeated message formats and large numbers of ciphertexts help attackers identify patterns and perform known-plaintext attacks. Therefore, the risk of key compromise and information leakage becomes higher.

**B. Evaluation of the Original Design (2 Marks)**

The original AES encryption provides strong security, but repeated use of the same key with an insecure encryption mode can expose patterns.

For example, if AES is used in ECB mode, identical plaintext blocks produce identical ciphertext blocks. Predictable headers can therefore reveal repeated patterns.

For a 128-bit AES key, the key space is:

\[ 2^{128}\approx 3.4\times10^{38} \]

This makes brute-force attacks impractical. However, a large key space alone cannot prevent poor key management or insecure encryption modes.

Bell-LaPadula still controls access through security levels, but it cannot fully prevent an authorized insider who already possesses the decryption key from copying decrypted information.

**C. Adaptation or Redesign (2 Marks)**

I recommend modifying the original design using the following security improvements:

1. Per-clinic keys: Provide separate encryption keys for all 25 clinics instead of sharing one key.
2. Per-session keys: Generate temporary keys for individual communication sessions.
3. Key rotation: Change encryption keys regularly and revoke compromised keys immediately.
4. Randomized encryption: Use AES-GCM with unique random nonces to prevent predictable ciphertext patterns and provide integrity protection.
5. Steganography: Hide encrypted reports inside medical scan images so that the reports are less visible during transmission.

6. Encrypt-then-embed: First encrypt the report using AES-GCM and then embed the encrypted data into the scan image.

These improvements reduce the impact of key compromise and make pattern analysis more difficult.

**D. Evidence-Based Defence (2 Marks)**

The modified design is stronger because AES provides a 128-bit or 256-bit key space, while separate clinic and session keys reduce the damage caused by one compromised key.

For example, if one clinic's key is compromised, the other 24 clinics can continue using their own keys. AES-GCM also protects the confidentiality and integrity of patient reports.

Steganography provides an additional layer by hiding encrypted reports inside medical scan images. However, it does not replace encryption because hidden data may still be discovered through steganalysis.

For usability, encryption, decryption and embedding should happen automatically in the background. Clinic staff should use a simple login system without manually handling encryption keys. A centralized key management system can reduce administrative difficulties across all 25 clinics.

Limitations: Classical techniques such as Caesar, Playfair and Vigenère cannot guarantee modern patient-data confidentiality, integrity or secure key management. They are suitable for academic experiments but not real healthcare deployment.

Conclusion:

The original design should be modified rather than completely replaced. Combining AES-GCM, per-clinic and per-session keys, Bell-LaPadula access control, key rotation and steganography provides better protection against insider attacks and information leakage. Regular auditing and monitoring are also necessary for real-world healthcare security.

**MARK DISTRIBUTION**

| **Task** | **Marks** |
|---|---|
| Task 1 – Threats, Attacks and Risk Evaluation | 4 |
| Task 2 – Security Goals Mapping | 3 |
| Task 3 – Bell-LaPadula Application and Critique | 5 |
| Task 4 – Cipher Design | 4 |
| Task 5 – Mathematical Analysis | 5 |
| Task 6 – Cryptanalytic Resistance | 4 |
| Task 7 – Transposition / Product Ciphers | 3 |
| Task 8 – Steganography Evaluation | 3 |
| Task 9 – Implementation & Testing | 4 |
| Task 10 – Experimental Evidence | 3 |
| Task 11 – Final Design Recommendation | 4 |
| **Subtotal** | **42** |
| Task 12 – Day-4 Design Challenge | **8** |
| **TOTAL** | **50** |